ITA1434
Ethical Hacking.

P. Venkat krishna
Reg No: 192324104

1) You are conducting a penetration test and discover that the client's production database contains real customer financial data. your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?

1. Introduction:-

Penetration testing is an authorized security assessment used to identify vulnerabilities in applications, networks, servers, and databases. The objective is to find security weaknesses before attackers can exploit them. SQL Injection is a serious web application vulnerability that occurs when user input is improperly included in SQL queries. The tester should prove the vulnerability without unnecessarily accessing, modifying, or exposing sensitive customer information.

2. Identify the vulnerability carefully.

→ The tester should first confirm wheather the suspected SQL Injection vulnerability is genuine using controlled testing. The tester should dump the complete database, modify customer records, delect transactions, change account balances, create unauthorized accounts, or execute destructive commands. Limiting exploitation reduces the possibility of financial loss, data corruption, privacy violations, and service disruption.

3. Notify the client security Team.

→ The tester should immediately inform the authorized security contact identified in the penentration testing agreement. The notification should explain the affected application, vulenerability, potential impact, testing already performed, and wheather any sensitive information was accidentally exposed. The client can then decide wheather additional testing is necessary and provide appropriate instructions.

4) use a safe Testing Environment

→ Further testing should preferably be performed in a staging or development environment. The testing environment should contain synthetic or anonymized data rather than real customer information. For example, instead of real bank account information, the test database can contain records such as Test Costomer, TXNool

6) Non-Destructive testing

If testing Production is explicitly authorized only controlled and non-destroctive techniques should be used. The tester should carefully control the number of requests, testing duration, database operations, and amount of information accessed

7) Product customer Financial Information.

customer financial information must be treated as confidential. If the tester accidentally encounters sensitive information, they should stop further access and collect only the minimum evidence required.

complete account numbers, transaction information, passwords, payment details, or other personal infor should not be unncessarily stored or shared.

8) Maintain Confidentiality:-

→All information obtained during the penetration test must be protected from unauthorized access. Test result, screenshots, logs and other evidence should never publish customer information, upload it to public websites, or use it for personal purpose.

9) Maintain an Audit Trail.

→The tester should document all important testingactivities The records should include the date and time of testing, affected systems, application endpoints, test accounts, vulnerability identified, actions performed, evidence collected, and communication with the client.

10) obtain written Authorization.

→written authorization must be obtained before starting the penetration test. The authorization should identity the client, testing organization authorized system.

11. Define the scope

The scope should clearly identify which system. are included and excluded from testing. It may include specific domains, applications, severs, APIs, or IP addiesses, Third-party systems, payment gateways, employee systems. or unrelated databases may need to be excluded.

12. prepare Roles of Engagement.

The roles of engagement doument defines how the penetration test most be perfromed. it should specify permitted testing methods, prohibiled activites testing times, emergency contacts, data handling proceddures, and reporting requirements.

13) identity sensitive systems.

-> Before the testing begins the organization should identity system that contain sensitive information.

conclusion:-

when a SQL injection vulnerability is discovered in a production database containing real customer financial information, the tester should stop unneccessary exploitation and immediately inform the authorized security team. only the minimum evidence required to demonstrate the vulnerability should be collected.

The main objective of penetration testion is to identify and demonstrate vulnerabilites safely so that they can be fixed without exposing customers, damaging data, or disrupting business operations.